ISO/IEC 27001:2022 Statement of Applicability — Extract

Certificate particulars

The information security management system operated by the service organisation has been assessed against ISO/IEC 27001:2022 and found to conform. Certificate ISMS-2026-04417 was issued on 10 February 2026 and is valid to 9 February 2029, subject to satisfactory surveillance in each intervening year. The certification body is accredited under the International Accreditation Forum multilateral recognition arrangement, and the certificate is verifiable in the accreditation body's public register.

Scope statement

The certified scope is: the design, development, operation and support of the cloud email encryption service, including the encryption gateway, the policy engine, the recipient portal, the key management plane, the tenant administration plane, and the engineering and operational functions that build and run them. The scope covers all residency zones in which the service is offered. Corporate functions with no role in operating the service are excluded from scope, and the exclusion is recorded with justification in the Statement of Applicability.

Statement of Applicability — extract

Statement of Applicability version 6.1, dated 22 January 2026, evaluates all 93 controls in Annex A of ISO/IEC 27001:2022. Ninety are applicable and implemented. Three are declared not applicable, each with a recorded justification: A.7.11 (supporting utilities) and A.7.12 (cabling security), both physical controls carried by the carved-out infrastructure provider and not operable by the service organisation; and A.5.7 (threat intelligence) is applicable but limited to commercially available and open sources, as classified national sources are not lawfully available to a private-sector provider in the operating jurisdictions.

Annex A control	Implementation summary	Status
A.5.15 Access control	Unique identities, federated sign-in, second factor for any access to tenant data, entitlements derived from role,	Implemented
A.5.23 Cloud services security	Supplier assessment before onboarding, contractual security terms, annual reassessment, exit plan per supplier.	Implemented
A.5.29 Security during disruption	Continuity arrangements per residency zone, exercised twice yearly, objectives published to customers.	Implemented
A.5.30 ICT readiness for continuity	Recovery objectives set per component, verified in exercise, deviations tracked to closure.	Implemented
A.8.9 Configuration management	Infrastructure defined as code, drift detected continuously, out-of-band changes blocked by policy.	Implemented
A.8.12 Data leakage prevention	Egress controls on production networks, content inspection on administrative export paths.	Implemented
A.8.16 Monitoring activities	Central event pipeline, detection rules under a documented lifecycle, 24x7 triage with severity-based response tim	Implemented
A.8.24 Use of cryptography	Cryptography policy setting approved algorithms, minimum key sizes and protocol versions; reviewed annually aga	Implemented

Annex A control	Implementation summary	Status
A.8.28 Secure coding	Secure coding standard, mandatory peer review, static analysis and dependency analysis gating merge.	Implemented
A.5.7 Threat intelligence	Commercial and open sources only; classified sources unavailable to the organisation.	Applicable, limited
A.7.11 Supporting utilities	Carried by the infrastructure provider under the carve-out.	Not applicable
A.7.12 Cabling security	Carried by the infrastructure provider under the carve-out.	Not applicable

Surveillance and internal audit

The certification cycle comprises the initial Stage 1 and Stage 2 assessment, annual surveillance in years two and three, and recertification at the end of year three. Surveillance covers a rotating subset of applicable controls selected by the external auditor on the basis of risk and prior findings; in practice roughly a third of applicable controls are examined at each surveillance visit. The internal audit programme covers the whole management system every twelve months, independently of the external cycle, and its findings feed the management review.

Nonconformities

The most recent surveillance raised two minor nonconformities and no major nonconformities. The first concerned a supplier reassessment completed nine days after its due date; corrected by moving reassessment scheduling into the same tracking system as the rest of the supplier lifecycle. The second concerned a detection rule retired without the retirement rationale being recorded; corrected by making the rationale field mandatory in the rule lifecycle workflow. Both corrective actions have been implemented and verified effective.

Management review

Executive management reviews the management system quarterly. Each review considers the risk register and treatment plan, performance against the defined security metrics, the status of internal and external audit findings, customer-raised security observations, and resourcing. Minutes are retained, and a redacted extract is available to customers under non-disclosure on request.